

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 1 頁，共 14 頁

單選題 50 題 (佔 100%)

D	1. 下列何項攻擊手法的目的是要破解密碼？ (A) 阻斷服務攻擊 (B) 網路連線攻擊 (C) 後門攻擊 (D) 字典攻擊
B	2. 下列何項是防火牆策略的最佳資安實踐？ (A) 允許所有的外部連入請求 (B) 預設拒絕所有連接，除非明確允許 (C) 預設允許所有連接，除非明確拒絕 (D) 不使用防火牆，以增加網路效能
C	3. 關於 SQL 注入 (SQL Injection) 攻擊的描述，下列何者較為適當？ (A) 使網站無法訪問 (B) 竊取電腦重要檔案 (C) 在資料庫中執行惡意 SQL 語句 (D) 破壞網路設備
B	4. 若希望在防火牆上設定，讓對外的所有連線預設為拒絕 (Deny)，只有經過許可的才允許通過，這種策略常被稱下列何項？ (A) 黑名單 (Blacklist) (B) 白名單 (Whitelist) (C) 預設通過 (Default Allow) (D) 動態篩選 (Dynamic Filter)

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 2 頁，共 14 頁

D	5. 公司部署的入侵偵測系統主要依靠簽章或特徵比對為偵測機制。當遭遇零時差（Zero-day）攻擊，入侵偵測系統的偵測結果最可能是下列何項？ (A) 大量正常流量被誤判為惡意，導致告警數量急遽上升 (B) 系統立即阻斷攻擊封包，並防止橫向擴散 (C) 入侵偵測系統因處理效率影響，造成封包轉送速度異常加快 (D) 攻擊流量未被標記為異常，直到後續分析才可能察覺
D	6. 若要在網路層面降低駭客橫向移動風險，最適合的設計是下列何項？ (A) 啟用 VPN（Virtual Private Network）加密流量 (B) 增加 DMZ（Demilitarized Zone）伺服器數量 (C) 使用 IDS（Intrusion Detection System）偵測可疑封包 (D) 採用網路分段（Network Segmentation）將整體網路劃分為多個較小的子網路或區域
B	7. 關於 VLAN（Virtual Local Area Network）與安全性的敘述，下列何者較為正確？ (A) 僅能提升效能，與安全性無關 (B) 可以減少廣播範圍並降低橫向攻擊風險 (C) 可取代防火牆的功能 (D) 僅能應用於無線網路環境
C	8. 在零信任架構下，若一個帳號憑證遭竊，下列何項機制最能降低駭客利用該憑證進行橫向移動？ (A) 使用靜態防火牆（Static Packet Filtering Firewall）規則 (B) 增加 DMZ（Demilitarized Zone）伺服器數量 (C) 啟用多因素驗證（Multi-factor authentication） (D) 啟用 NAT（Network Address Translation）對應

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 3 頁，共 14 頁

A	9. 在設定防火牆的規則時，下列哪一種策略可以有效減少誤報並提高安全性？ (A) 使用最小權限原則，僅允許必要的流量 (B) 設定所有流量為允許，然後逐步添加拒絕規則 (C) 僅依賴預設的防火牆規則 (D) 定期重置防火牆設定以清除舊規則
A	10. 下列何種攻擊方式會利用大量偽造的網路流量，癱瘓目標伺服器？ (A) 分散式阻斷服務（DDoS） (B) 社交工程（Social Engineering） (C) 跨網站指令碼（XSS） (D) SQL 注入（SQL Injection）
C	11. 下列哪一項是防火牆的主要功能之一，能夠防止未經授權的存取？ (A) 加密資料傳輸 (B) 監控網路流量 (C) 檢查和過濾進出網路的封包 (D) 提供虛擬私人網路（Virtual Private Network, VPN）連接
A	12. 某公司內部郵件傳輸需要保護機密性，下列何者為最適當採用的安全通訊協定？ (A) SMTP 搭配 STARTTLS (B) HTTP 搭配 TLS (C) DNSSEC (D) Telnet

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 4 頁，共 14 頁

B	13. 在完成 HTTPS 網站設定後，瀏覽器仍顯示「憑證不被信任」的錯誤訊息，最可能的原因是下列何項？ (A) 使用的憑證尚未過期 (B) 使用了自簽憑證 (C) TLS 版本太新，瀏覽器不支援 (D) 加密演算法長度太長
B	14. 依照 IP 的來源地區 (GEOIP) 限制連線，這種防火牆的運作，主要是針對開放式系統互聯模型 (OSI Model) 中哪一層來進行？ (A) 第 2 層 資料連結層 (Data Link Layer) (B) 第 3 層 網路層 (Network Layer) (C) 第 4 層 傳輸層 (Transport Layer) (D) 第 5 層 會議層 (Session Layer)
B	15. 如附圖所示，某作業系統在同一天釋出四個安全更新。若資安團隊必須依照資安風險優先級安排安裝順序，最合理的順序是下列何項？ 1. 修補 Kernel 本地提權漏洞 (已公開 exploit 程式，CVSS 9.0，高風險) 2. 修補 OpenSSL 資料外洩漏洞 (尚未出現 exploit，但影響機敏資料，CVSS 7.5，中高風險) 3. 修補 GUI 顯示錯誤 (功能異常) 4. 修補低風險應用程式錯誤 (僅影響單一非關鍵應用，CVSS 3.0，低風險) (A) 3 -> 2 -> 1 -> 4 (B) 1 -> 2 -> 4 -> 3 (C) 2 -> 1 -> 3 -> 4 (D) 2 -> 1 -> 4 -> 3
C	16. 在 Windows 作業系統中，下列何項功能之主要目的用來限制某些應用程式的執行，以提升系統安全性？ (A) Microsoft IoT Defender (B) BitLocker (C) AppLocker (D) Task Scheduler

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 5 頁，共 14 頁

A	17. 若系統管理員採用「基於角色的存取控制（Role-Based Access Control, RBAC）」來管理伺服器，下列何項最能反映 RBAC 與傳統 DAC（Discretionary Access Control）的主要差異？ (A) RBAC 的存取決策依據使用者所屬角色，DAC 的存取決策依據資源擁有者的設定 (B) RBAC 屬於強制式存取控制的一種，DAC 屬於集中式管理模型 (C) DAC 無法支援多使用者環境，RBAC 則能依角色分派給多人 (D) 在 RBAC 中，使用者可直接修改自己資源的存取權限；在 DAC 中則需透過系統管理員
B	18. 為了讓作業系統變得更安全、更難以入侵，通常企業會對作業系統進行安全強化（Harden），下列何項不是 Linux 作業系統經常採用的安全強化機制？ (A) 設定密碼原則、登入錯誤次數限制，並且使用 fail2ban 服務將登入錯誤次數太多的使用者列入黑名單 (B) 關閉所有非必要的系統服務與通訊協定，但是保留 nmap，以便進行自我掃描跟檢測 (C) 禁止使用 root 帳號登入 SSH 服務，只能使用一般使用者的帳號，若要提升權限變成 root 則必須使用 sudo 指令 (D) 使用 iptables 防火牆功能限制存取來源，讓連線來源最小化
A	19. 網路釣魚的常見手法，「不」包含下列何項？ (A) 中間人攻擊（Man-in-the-Middle） (B) 類似的網域名稱 (C) 吸引人的優惠 (D) 帳號鎖定通知

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 6 頁，共 14 頁

B	20. 下列哪一種攻擊手法試圖利用作業系統對於記憶體存取的管理不當，透過將惡意程式碼注入到應用程式的記憶體空間中，從而執行未經授權的操作？ (A) 中間人攻擊 (Man-in-the-Middle) (B) 緩衝區溢位攻擊 (Buffer Overflow Attack) (C) 分散式拒絕服務攻擊 (DDoS) (D) 旁通道攻擊 (Side-channel Attack)
D	21. OWASP 所列出的 10 大弱點列表中，注入 (Injection) 一向是被關注的重點。下列何項攻擊方式較「不」屬於此項範疇？ (A) SQL 注入 (SQL Injection) (B) 命令注入 (Command Injection) (C) 跨站攻擊 (Cross-Site Scripting) (D) 跨站偽造 (Cross-Site Request Forgery)
A	22. 下列何項「不」屬於常見的資源存取控制模式？ (A) 以長效為基礎的安全模式 (Permanent-based Access Control, PBAC) (B) 任意式安全模式 (Discretionary Access Control, DAC) (C) 強制式安全模式 (Mandatory Access Control, MAC) (D) 以角色為基礎的安全模式 (Role-based Access Control, RBAC)

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 7 頁，共 14 頁

C	23. 防火牆 (Firewall) 設備內通常擁有一整套網路安全規則，可以用來監控、篩選和控制進出特定範例的網路封包內容與流量。配置防火牆設備的主要目的，是在受信任的內部網路和不受信任的外部網路之間建立屏障。請問下一個世代防火牆 NGFW (Next-Generation Firewall) 較「不」具備下列何項功能？ (A) 遠端 VPN 連線 (B) 資料外洩防護 (Data Loss Prevention, DLP) (C) 程式源始碼掃描 (D) 沙箱 (Sandbox) 運作與程式分析
C	24. 下列何項措施最能有效防止阻斷服務攻擊 (Denial-of-Service, DoS) (A) 隱藏伺服器的位置 (B) 使用內容傳遞網路 (CDN) (C) 限制單個 IP 位址的請求速率 (D) 啟用伺服器的日誌記錄
B	25. 在 Web 應用程式中，若未對使用者輸入進行適當的驗證與過濾，攻擊者可能利用下列何種攻擊方法，輸入惡意資料進而未經授權地存取或修改資料庫中的資料？ (A) 跨站腳本攻擊 (Cross-Site Scripting, XSS) (B) SQL 注入攻擊 (SQL Injection) (C) 跨站請求偽造 (Cross-Site Request Forgery, CSRF) (D) 釣魚攻擊 (Phishing)
A	26. 下列何項措施最能有效防禦跨站請求偽造 (Cross-Site Request Forgery, CSRF) 攻擊？ (A) 在表單中加入隱藏的隨機令牌 (Token) (B) 對使用者輸入的資料進行編碼 (C) 使用 HTTPS 協定傳輸資料 (D) 設置強密碼策略

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 8 頁，共 14 頁

A	27. 下列何種攻擊方法是利用網頁的輸入欄位或網址，插入惡意的腳本(Script)，使其他使用者在瀏覽該網頁時執行該腳本？ (A) 跨站腳本攻擊 (Cross-Site Scripting, XSS) (B) 跨站請求偽造 (Cross-Site Request Forgery, CSRF) (C) 釣魚攻擊 (Phishing) (D) 阻斷服務攻擊 (Denial-of-Service, DoS)
A	28. 如附圖所示，攻擊者透過修改查詢參數「 account 」為任意帳號即可存取資訊，關於此應用程式缺陷的敘述，下列何者正確？ <code>https://vulnerable.site/app/profile?account=victim</code> (A) 存取控制失效 (Broken Access Control) (B) 密碼機制失效 (Cryptographic Failures) (C) 注入攻擊 (Injection) (D) 安全日誌與監控失效 (Security Logging and Monitoring Failures)
D	29. 關於應用系統開發過程納入資訊安全要求的描述，下列何項正確？ (A) 各個程式設計皆有一套執行方式，較難書面記錄以套用於資訊系統撰寫流程 (B) 應用系統安全測試需於開發完成之後再進行，以免影響程式開發時間流程 (C) 應用系統委外第三方廠商開發，內部建立之開發安全工程原則不適用要求委外開發的活動 (D) 曾經發生常見導致資訊安全脆弱性之程式開發實務作法及缺陷，可納入文件做為開發遵守依據

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 9 頁，共 14 頁

C	30. 下列何項「不」是常見的網站設計安全漏洞？ (A) 脆弱的身分識別控制，造成權限控制失效（Broken Access Control） (B) 缺乏有效的漏洞修補管理程序和安全設定（Security Configuration） (C) 雲端服務興起，缺乏資訊基礎設施（Information Infrastructure）並造成資安記錄及監控分散（Security Logging and Monitoring Spread） (D) 有效的商業電子郵件詐騙（BEC），並造成伺服器端請求偽造（Server-Side Request Forgery, SSRF）
A	31. 當偵測到一個可疑的惡意程式在企業內部網路中傳播，下列哪一項是最適當的立即處理方式？ (A) 斷開受感染設備的網路連線 (B) 關閉所有防毒軟體以防止誤報 (C) 向所有員工發送通知，要求他們自行檢查電腦 (D) 重新安裝受感染設備的作業系統
D	32. 在惡意程式的「預防與阻擋」策略中，下列何項技術的核心原則是在個人電腦「預設全部禁止，僅允許明確授權的應用程式執行」，以達到最高的安全性？ (A) CDR 內容解除與重建（Content Disarm and Reconstruction） (B) 應用程式黑名單（Application Blacklisting） (C) 網路防火牆（Network Firewall） (D) 應用程式白名單（Application Whitelisting）

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 10 頁，共 14 頁

C	33. 遠端瀏覽器隔離 (Remote Browser Isolation)，是一種先進的網路安全技術，技術上主要是透過下列何種核心機制，以保護使用者免於遭受網頁惡意程式的攻擊？ (A) 在本機電腦的瀏覽器中直接掃描網頁程式碼，並比對已知的惡意軟體特徵碼資料庫 (B) 在網站伺服器前端部署一道防線，用以保護網站本身不被惡意流量 (如 SQL Injection) 攻擊 (C) 將所有網頁內容的載入與執行，都放在一個遠端的、隔離的雲端或伺服器環境中進行，僅將安全的視覺影像傳回給使用者 (D) 根據一份不斷更新的黑名單，禁止使用者存取已知的惡意或釣魚網站
B	34. 企業在做備份計畫時，要考慮還原的正確性、完整性，下列何者描述較「不」適切？ (A) 系統的金鑰最好可以另外備份 (B) 還原僅限特權帳號可以執行 (C) 備份空間要至少兩成的緩衝 (D) 備份資料最好有一份可以離線
C	35. 某公司於每日的凌晨 1 點進行備份，每日皆進行完整備份 (Full Backup)，假設需要還原至週三晚上 9 點時的狀況，需要下列何項備份檔案才能完成上述工作？ (A) 該週日的備份即可 (B) 該週三的備份即可 (C) 該週四的備份即可 (D) 該週四前所有的備份檔案

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 11 頁，共 14 頁

D	36. 在資訊安全領域，下列何種技術能夠確保即使攻擊者成功取得敏感資料，但無法直接解讀其內容？ (A) 數位簽章 (Digital Signature) (B) 非破壞性資料壓縮 (Lossless Compression) (C) 訊息摘要 (Message Digest) (D) 隱寫術 (Steganography)
B	37. 某企業採用「每日增量備份＋每週完整備份」的方式。這樣設計的主要目的為下列何項？ (A) 減少備份檔案加密強度 (B) 降低儲存空間與備份時間成本 (C) 提高應用系統效能優先度 (D) 防止惡意程式注入
C	38. 企業採用混合式備份策略：本地快照 (Snapshot)＋雲端異地備份 (Offsite Backup)。在一次大規模勒索軟體攻擊中，攻擊者利用被竊取的管理者帳號，刪除了雲端的備份檔案，導致資料無法復原。請問此案例最主要暴露了下列何項備份管理風險？ (A) 備份資料未經壓縮，導致空間不足 (B) 備份存放在與生產系統同一環境 (C) 備份缺乏不可變性 (Immutable Backup) 與良好的存取控管 (D) 備份採用增量模式，導致復原速度過慢
A	39. 請問下列日誌記錄相關的系統或標準，何項較「不」適合用於 Linux 環境？ (A) Windows Event Viewer (B) RFC 5424 (C) Syslog-NG (D) rsyslogd

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 12 頁，共 14 頁

C	40. 在設計應用程式的日誌管理時，下列哪一種做法最能幫助快速偵測並回應潛在的安全事件？ (A) 只記錄應用程式的主要功能操作，可忽略登入及權限變更等活動 (B) 將日誌以純文字格式儲存在本地伺服器上，不需備份 (C) 設定日誌警報機制，在偵測到異常行為時即時通知管理員 (D) 定期刪除日誌，以避免佔用過多儲存空間
C	41. 在設計「日誌輪替」(Log Rotation) 機制時，其主要目標為下列何項？ (A) 永久保存所有日誌，以確保不遺漏任何資訊 (B) 只記錄特定類型的日誌，例如錯誤日誌或訪問日誌，忽略其他日誌 (C) 根據時間或檔案大小限制日誌，並自動歸檔或刪除舊日誌 (D) 定期手動刪除所有日誌檔案，以釋放存儲空間
B	42. 關於確保日誌的完整性，下列敘述何項最為適切？ (A) 禁止所有人存取日誌，僅允許管理員修改日誌內容，以確保記錄正確 (B) 記錄日誌變更歷史，並使用數位簽章或雜湊技術來驗證日誌的完整性 (C) 透過壓縮技術對日誌進行壓縮，確保儲存時間最大化 (D) 只保留最近七天的日誌，其他日誌自動刪除
C	43. 在日誌管理 (Log Management) 流程中，「日誌收集」(Log Collection) 階段最主要的目的為下列何項？ (A) 即時分析日誌以偵測威脅 (B) 對日誌進行加密以確保傳輸安全 (C) 將分散在不同來源的日誌資料，系統性地彙整集中存放 (D) 刪除不重要的日誌以節省儲存空間

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 13 頁，共 14 頁

D	44. 下列哪一個漏洞未在 OWASP Cloud-Native Application Security Top 10 之中？ (A) Injection flaws (B) Improper authentication & authorization (C) Insecure secrets storage (D) Server-Side Request Forgery
B	45. 下列何項驗證「不」是專門針對雲端機房的驗證制度？ (A) CSA STAR (B) SOC 2 (C) ISO/IEC 27017 (D) ISO/IEC 27018
B	46. 某 Android 應用的 WebView 為方便除錯，沒有關閉「JavaScript 介面」，暴露 Java 物件給載入的網頁。攻擊者誘導使用者開啟惡意網頁，該網頁呼叫被暴露的 Java 方法以讀取本機檔案與敏感資料。這種攻擊方法稱之為下列何項？ (A) 預設憑證信任（Trust All Certificates） (B) WebView 注入攻擊（WebView Injection） (C) Session 攻擊 (D) NFC 重送攻擊
C	47. 使用者在手機上安裝了一個來源不明的 APK 檔案，結果裝置被惡意程式竊取聯絡人與簡訊內容。這種風險最主要源自下列何項？ (A) 使用越獄或 Root 後的裝置 (B) 啟用生物辨識登入 (C) 從不可信來源安裝應用程式 (D) 未設定螢幕自動鎖定

114 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

卷號：I12-4201

考試日期：114 年 11 月 8 日

第 14 頁，共 14 頁

C	48. 在手機上，某惡意應用程式在背景持續存取麥克風與攝影機，導致個資外洩。防範此類攻擊最有效的方法為下列何項？ (A) 定期清理快取 (B) 啟用生物辨識登入 (C) 嚴格管理應用程式的權限 (D) 降低能耗
B	49. 物聯網設備常用的遠端管理設定，包含 Telnet 與 SSH，請問下列何項敘述正確？ (A) Telnet 較安全，使用 Port 22 (B) SSH 較安全，使用 Port 22 (C) Telnet 較安全，使用 Port 23 (D) SSH 較安全，使用 Port 23
C	50. 物聯網感知層主要作用是全面感知外界資訊，包括物體識別、資訊收集等功能。請問對於物聯網感知層的描述何者不正確？ (A) 物聯網的感知層主要由感測裝置和讀取與識別裝置組成 (B) 物聯網安全需求應包括判斷與阻斷惡意節點與其行為，並保證阻斷惡意節點後網路的連通性 (C) 感知層的資訊通常透過應用層與外界連通，才能作為應用層正確控制決策的主要依據 (D) 無線感測器是物聯網感知層重要的組成部分，由於無線感測器採用無線通訊，攻擊者可以輕易實施監聽訊號，並儲存監聽資料